

Week 4 Lab: Port Scanning

CCS6324 - Ethical Hacking and Penetration Testing

Duration: 1 Hour

Difficulty: Beginner-Friendly

Works on: Windows & macOS (using Kali Linux VM)



SUPER IMPORTANT - READ FIRST!

Legal Warning

"Port scanning without permission is a CRIME!"

Today's Rules:

1. ☒ ONLY scan targets we provide
2. ☒ Use Metasploitable VM (our practice target)
3. ☒ NEVER scan the MMU network
4. ☒ NEVER scan external websites
5. ☒ NEVER scan your neighbor's WiFi

Why This Matters:

- **In Malaysia:** Up to 10 years imprisonment under the Computer Crimes Act
 - **Real example:** Student in Singapore scanned school network "for fun" → expelled + criminal record
 - **Be smart:** Always get written permission!
-

PART 1: SETUP YOUR LAB (10 minutes)

Step 1: Start Your VMs

You Need TWO VMs Running:

VM 1: Kali Linux (Your Attack Machine)

1. Open VirtualBox/VMware
2. Start **Kali Linux**
3. Login: `kali / kali`

VM 2: Metasploitable 2 (Your Target Machine)

1. Start **Metasploitable 2**
2. Login: `msfadmin / msfadmin`

Don't have Metasploitable?

- Download: <https://sourceforge.net/projects/metasploitable/>
 - It's a deliberately vulnerable Linux machine for practice!
-

Step 2: Check IP Addresses

On Kali Linux – Terminal Emulator:

Type:

```
ip a
```

Look for:

```
eth0: inet 192.168.100.10/24 or 10.10.0.6/24
```

 **Write down Kali IP:** _____

On Metasploitable:

Type:

```
ifconfig
```

Look for:

```
eth0: inet addr:192.168.100.15 or 10.10.0.5
```

 **Write down Metasploitable IP:** _____

Step 3: Test Connectivity

From Kali, type:

```
ping 192.168.100.15
```

(Replace with YOUR Metasploitable IP!)

Expected output:

```
64 bytes from 192.168.100.15: icmp_seq=1 ttl=64 time=0.5 ms
```

Press **Ctrl+C** to stop.

☑ If you see this, you're connected!

✗ If "Destination Host Unreachable":

- Check that both VMs are on the same network (Internal/NAT Network)
- Check IP addresses are in the same range

PART 2: YOUR FIRST NMAP SCAN (10 minutes)

What is Nmap?

Nmap = Network Mapper

Think of it like a "building inspector" checking all the doors (ports) to see which are open!

Scan 1: Basic Scan (Just Top Ports)

What we're doing: Check the most common 1000 ports

Type this:

```
nmap 192.168.100.15
```

(Use YOUR target IP!)

What Each Part Means:

Part	Meaning
nmap	The tool we're using
192.168.100.15	The target IP address

What happens:

- Nmap checks the 1000 most common ports
- Takes about 2-30 seconds

- Shows which ports are open

Expected Output:

```
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 192.168.100.15
Host is up (0.0005s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql

Nmap done: 1 IP address (1 host up) scanned in 2.15 seconds
```

Understanding the Output:

Column	Meaning	Example
PORT	Port number/protocol	80/tcp
STATE	Is it open?	open
SERVICE	What runs there	http (website)

Scan 2: Scan Specific Ports

What we're doing: Check only ports we care about

Type this:

```
nmap -p 80,443,22 192.168.100.15
```

What Each Part Means:

Part	Meaning
-p 80,443,22	Only scan these 3 ports
80	HTTP (websites)
443	HTTPS (secure websites)
22	SSH (remote login)

Time: Only 2-3 seconds (vs. 2-30 seconds for 1000 ports!)

Scan 3: Scan ALL Ports

What we're doing: Check all 65,535 ports (it takes time!)

Type this:

```
nmap -p- 192.168.100.15
```

What Each Part Means:

Part	Meaning
-p-	Scan ALL ports (1-65535)

 **This will take 1-10 minutes!** Be patient!

While it's running, move to next section!

PART 3: DIFFERENT SCAN TYPES (15 minutes)

Understanding Scan Types

Remember the TCP handshake?

```
SYN → SYN-ACK → ACK
```

Different scans use this handshake differently!

Type 1: TCP Connect Scan (Full Connection)

What it does: Completes full handshake

Command:

```
nmap -sT 192.168.100.15
```

What Each Part Means:

Part	Meaning
-sT	TCP Connect scan
T	"TCP" Full connection

Characteristics:

- ☒ Most reliable
- ☒ Works without sudo
- ☒ Easily detected (shows in logs)
- ☒ Slowest

When to use: When you don't have root/admin access

Type 2: SYN Scan (Stealth Scan) ★ MOST POPULAR

What it does: Sends SYN, gets SYN-ACK, then stops (never completes)

Command:

```
sudo nmap -sS 192.168.100.15
```

What Each Part Means:

Part	Meaning
sudo	Run with admin privileges (required!)
-sS	SYN scan (stealth)
s = "SYN"	Only first step of handshake

Characteristics:

- ☒ Fast
- ☒ Stealthier than TCP Connect
- ☒ Most commonly used
- ☒ Requires root/sudo

When to use: 95% of the time! This is the default for professionals.

Type 3: UDP Scan

What it does: Checks UDP ports (different from TCP!)

Command:

```
sudo nmap -sU 192.168.100.15
```

What Each Part Means:

Part	Meaning
sudo	Admin privileges needed
-sU	UDP scan
U = "UDP"	Different protocol than TCP

Characteristics:

- ☒ Only way to find UDP services
- ☒ VERY slow (can take hours!)
- ☒ Results are uncertain

 **Note:** UDP scans take FOREVER. We'll just scan a few ports:

```
sudo nmap -sU -p 53,161,514 192.168.100.15
```

(Just DNS, SNMP, Syslog)

Comparing Scan Types

Let's compare them side-by-side!

Scan the SAME target with 3 different methods:

```
# Method 1: TCP Connect
time nmap -sT -p 1-100 192.168.100.15

# Method 2: SYN Scan
time sudo nmap -sS -p 1-100 192.168.100.15

# Method 3: Fast but risky
time sudo nmap -sS -T4 -p 1-100 192.168.100.15
```

What is time?

It measures how long the command takes!

Fill in Your Results:

Scan Type	Time Taken	Ports Found
TCP Connect (-sT)	_____ seconds	___ open ports
SYN Scan (-sS)	_____ seconds	___ open ports
Fast SYN (-sS -T4)	_____ seconds	___ open ports

Question: Which was fastest? Which was stealthiest?

PART 4: PING SWEEP (10 minutes)

What is a Ping Sweep?

Ping Sweep = “Who’s home?” check

Instead of scanning every port on every computer, we first find which computers are awake!

Scan 1: Find Live Hosts

What we're doing: Check which IPs are responding

Command:

```
nmap -sn 192.168.100.0/24
```

What Each Part Means:

Part	Meaning
-sn	"Skip port scan, just check if alive"
n = "No port scan"	Only do host discovery
192.168.100.0/24	Entire network (IPs 1-254)

Expected Output:

```
Nmap scan report for 192.168.100.1
Host is up (0.0001s latency).
```

```
Nmap scan report for 192.168.100.10
Host is up (0.00020s latency).
```

```
Nmap scan report for 192.168.100.15
Host is up (0.00035s latency).
```

```
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.15 seconds
```



How many hosts are up? _____

Scan 2: Ping Sweep and Then Scan

What we're doing: Find live hosts, then scan their ports

Command:


```
sudo nmap -sS 192.168.100.0/24
```

What happens:

1. Nmap pings all 256 IPs
2. Finds which ones respond
3. THEN scans ports on responding hosts only

Time saved: Huge! Instead of scanning 256×1000 ports, maybe only 3×1000!

Understanding Network Ranges

What does /24 mean?

192.168.100.0/24 = All IPs from 192.168.100.1 to 192.168.100.254

Other examples:

Notation	What It Covers	How Many IPs
192.168.100.50	Just one IP	1
192.168.100.0/24	.1 through .254	256
192.168.100.1-50	.1 through .50	50
192.168.100.*	Same as /24	256

PART 5: ADVANCED NMAP OPTIONS (10 minutes)

Getting More Information

Scan 1: Service Version Detection

What it does: Finds out WHAT version of software is running

Command:

```
sudo nmap -sV 192.168.100.15
```

What Each Part Means:

Part	Meaning
-sV	Version detection
v = "Version"	Probe services to identify versions

Example Output:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu))
```

Why this matters: Knowing versions helps find vulnerabilities!
(Example: "OpenSSH 4.7p1" is VERY old and has known exploits!)

Scan 2: Operating System Detection

What it does: Guesses what OS the target is running

Command:

```
sudo nmap -O 192.168.100.15
```

What Each Part Means:

Part	Meaning
-O	OS detection
o = "Operating System"	Fingerprint the OS

Example Output:

```
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
```

Scan 3: Aggressive Scan (All the Things!)

What it does: Version detection + OS detection + scripts + traceroute

Command:

```
sudo nmap -A 192.168.100.15
```

What Each Part Means:

Part	Meaning
-A	Aggressive scan (enable all)
A = "Aggressive"	OS, version, scripts, traceroute

 **It takes longer but gives TONS of info!**

Example Output:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1
|_ssh-hostkey: 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
80/tcp    open  http      Apache httpd 2.2.8 ((Ubuntu))
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu)
```

OS details: Linux 2.6.9 - 2.6.33

Timing Templates (Speed Control)

What are timing templates?

They control how FAST Nmap scans.

Command format:

```
nmap -T[0-5] target
```

The Options:

Template	Name	Speed	When to Use
-T0	Paranoid	Insanely slow	Evade IDS (takes hours!)
-T1	Sneaky	Very slow	Evade IDS
-T2	Polite	Slow	Don't overwhelm target
-T3	Normal	Default	Most situations
-T4	Aggressive	Fast	LANs, good connections
-T5	Insane	Very fast	May miss results, loud

Try Different Speeds:

```
# Slow and stealthy
sudo nmap -sS -T2 -p 1-100 192.168.100.15
```

```
# Fast and aggressive
sudo nmap -sS -T4 -p 1-100 192.168.100.15
```

Compare the times!

PART 6: SAVING YOUR RESULTS (5 minutes)

Why Save Results?

- Document your findings
 - Compare scans over time
 - Share with team
 - Include in reports
-

Output Format 1: Normal Text

Command:

```
nmap 192.168.100.15 -oN scan_results.txt
```

What Each Part Means:

Part	Meaning
-oN	Output Normal format
scan_results.txt	Filename to save

View the file:

```
cat scan_results.txt
```

Output Format 2: XML (For Tools)

Command:

```
nmap 192.168.100.15 -oX scan_results.xml
```

Why XML? Other tools can read it (like vulnerability scanners)

Output Format 3: Grepable (For Searching)

Command:

```
nmap 192.168.100.15 -oG scan_results.grep
```

Why Grepable? Easy to search with `grep` command

Example:

```
# Find all hosts with port 80 open
grep "80/open" scan_results.grep
```

Save in ALL Formats at Once!

Command:

```
nmap 192.168.100.15 -oA scan_results
```

What Each Part Means:

Part	Meaning
------	---------

-oA	Output All formats
-----	--------------------

Creates 3 files:

- scan_results.nmap (normal)
 - scan_results.xml (XML)
 - scan_results.gnmap (grepable)
-

PART 7: BASH SCRIPTING FOR AUTOMATION (10 minutes)

What is a Bash Script?

A **bash script** is a file containing commands that run automatically!

Think of it like a recipe: write the steps once, then the computer follows them!

Script 1: Simple Scan Script

Step 1: Create the Script

Type:

```
nano scan_script.sh
```

Step 2: Write the Script

Type this into the file:

```
#!/bin/bash
# My First Port Scanning Script

echo "Starting port scan..."
echo "Target: $1"
```

```
nmap -sS -p 1-1000 $1
```

```
echo "Scan complete!"
```

Step 3: Save and Exit

- Press **Ctrl+O** to save
- Press **Enter** to confirm
- Press **Ctrl+X** to exit

Step 4: Make it Executable

Type:

```
chmod +x scan_script.sh
```

Translation: "Make this file executable (runnable)"

Step 5: Run Your Script!

Type:

```
sudo ./scan_script.sh 192.168.100.15
```

What happens:

- \$1 gets replaced with 192.168.100.15
- Script runs Nmap automatically
- Shows progress messages

Script 2: Scan Multiple Targets

Create new script:

```
nano multi_scan.sh
```

Type:

```
#!/bin/bash
# Scan Multiple Targets

echo "Scanning multiple targets..."

# List of targets
targets="192.168.100.10 192.168.100.15 192.168.100.20"

# Loop through each target
for target in $targets
do
```

```
        echo "Scanning $target..."
        nmap -sS -F $target -oN result_$target.txt
        echo "Done with $target"
done

echo "All scans complete!"
```

Save, make executable, and run:

```
chmod +x multi_scan.sh
sudo ./multi_scan.sh
```

Script 3: Advanced Automated Scanner

Create:

```
nano auto_scanner.sh
```

Type:

```
#!/bin/bash
# Automated Network Scanner
# Usage: ./auto_scanner.sh <network>

if [ -z "$1" ]; then
    echo "Usage: $0 <network>"
    echo "Example: $0 192.168.100.0/24"
    exit 1
fi

NETWORK=$1
DATE=$(date +%Y%m%d_%H%M%S)
OUTDIR="scan_$DATE"

echo "=== Automated Scanner ==="
echo "Network: $NETWORK"
echo "Date: $DATE"

# Create output directory
mkdir -p $OUTDIR

# Step 1: Find live hosts
echo "[1/3] Finding live hosts..."
nmap -sn $NETWORK -oG $OUTDIR/live_hosts.txt

# Extract live IPs
grep "Up" $OUTDIR/live_hosts.txt | cut -d " " -f 2 > $OUTDIR/targets.txt

# Step 2: Port scan each live host
echo "[2/3] Scanning ports on live hosts..."
while read target; do
    echo "    Scanning $target..."
    nmap -sS -sV -p- $target -oA $OUTDIR/scan_$target
done < $OUTDIR/targets.txt

# Step 3: Summary
echo "[3/3] Generating summary..."
```

```
cat $OUTDIR/targets.txt | wc -l > $OUTDIR/summary.txt
echo "Scan complete! Results in $OUTDIR/"
```

Save, make executable:

```
chmod +x auto_scanner.sh
```

Run:

```
sudo ./auto_scanner.sh 192.168.100.0/24
```

What it does:

1. Finds all live hosts
2. Scans each one thoroughly
3. Saves everything organized by date

PART 8: ANALYZING RESULTS (5 minutes)

Reading Nmap Output

Example Scan Result:

```
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
80/tcp    open  http
```

What to Look For:

Finding	What It Means	Security Risk
Port 21 (FTP)	File transfer	Often has weak passwords
Port 22 (SSH)	Remote login	Brute force attacks possible
Port 23 (Telnet)	Old remote login	⚠️ UNENCRYPTED! Very bad!
Port 25 (SMTP)	Email server	Spam relay risk
Port 80 (HTTP)	Website	Check for vulnerabilities
Port 3389 (RDP)	Windows remote desktop	Ransomware target!

Red Flags (Dangerous Findings)

Critical Issues:

1. **Telnet (23) is open**
 - Everything sent in plain text!
 - Passwords visible to anyone sniffing
 2. **FTP (21) is open**
 - Often has default passwords
 - Anonymous login may be enabled
 3. **SMB (445) is open to internet**
 - WannaCry ransomware used this!
 - Should only be internal
 4. **Database ports open to world**
 - MySQL (3306)
 - PostgreSQL (5432)
 - MongoDB (27017)
-

Creating Your Report

Template:

=== PORT SCAN REPORT ===

Date: [Today's date]

Target: [IP address]

Scanner: Nmap 7.94

SUMMARY:

- Total ports scanned: ____
- Open ports found: ____
- Services identified: ____

OPEN PORTS:

[List each open port, service, version]

HIGH-RISK FINDINGS:

[List any dangerous ports]

RECOMMENDATIONS:

[What should be fixed]

SCAN COMMAND USED:

[The nmap command you ran]

QUICK REFERENCE CARD

Essential Nmap Commands

```
# Basic scan (top 1000 ports)
nmap 192.168.100.15
```

```
# Scan specific ports
nmap -p 80,443 192.168.100.15

# Scan all ports
nmap -p- 192.168.100.15

# SYN scan (stealth, requires sudo)
sudo nmap -sS 192.168.100.15

# Service version detection
sudo nmap -sV 192.168.100.15

# OS detection
sudo nmap -O 192.168.100.15

# Aggressive scan (everything!)
sudo nmap -A 192.168.100.15

# Ping sweep (find live hosts)
nmap -sn 192.168.100.0/24

# Fast scan (top 100 ports)
nmap -F 192.168.100.15

# Save output
nmap 192.168.100.15 -oA results

# Scan with timing
sudo nmap -T4 -sS 192.168.100.15
```

TROUBLESHOOTING

Problem: "You requested a scan type which requires root privileges"

Solution: Add `sudo` before the command

```
sudo nmap -sS 192.168.100.15
```

Problem: "Failed to resolve given hostname"

Solution: Check IP address is correct, use IP not hostname

Problem: Scan is taking forever

Solution: Use faster timing or scan fewer ports

```
nmap -T4 -F 192.168.100.15 # Fast, top 100 ports only
```

Problem: All ports show as "filtered"

Solution: Target has firewall. Try:

```
sudo nmap -Pn 192.168.100.15 # Skip ping, assume host is up
```

Problem: "Cannot find device eth0"

Solution: Check your network interface name

```
ip a # See what interfaces you have
```

CLEANUP

After Lab:

1. **Stop long-running scans:**
 2. # Press Ctrl+C in terminal
 3. **Remove scan results (optional):**
 4. `rm *.txt *.xml *.gnmap scan_*`
 5. **Document your findings** for the future reference!
-

END OF LAB ACTIVITIES

Great job! You now know how to scan networks like a professional! 🎉